TRAVELPAY ECOSYSTEM

Tam Texniki Arxitektura, Verilənlər Bazası Sxemi və Funksional Bələdçi

Ağıllı Turizm və Çoxvalyutalı Rəqəmsal Ödəniş Platforması (Core FinTech)

Layihə Adı:	TravelPay — Smart Tourism Wallet & Real-Time Fraud Engine
Backend Çərçivəsi:	Laravel 11.x (PHP 8.4 LTS), RESTful API, Sanctum Auth
Verilənlər Bazası:	MySQL 8.0 (Docker container: travelpay_mysql, Port: 3307)
Frontend Layları:	1. Blade Single-Page Application (Vanilla JS + TailwindCSS) 2. React Admin Suite (React 19, TypeScript, Vite)
Mühüm Mühərriklər:	Risk & Fraud Engine (0-100), Double-Entry Ledger, RBAC Matrix, Threat Shield WAF
Sənəd Versiyası:	v2.4 — Tam Ətraflı Texniki Spesifikasiya
Tarix:	2026-cı il Oktyabr

Məzmun Xülasəsi:

Bu sənəd TravelPay platformasının tam arxitektura quruluşunu, daxili məntiqini, verilənlər bazasındakı bütün cədvəlləri və onların arasındakı Foreign Key (Xarici Açar) əlaqələrini, backend-də istifadə olunan servisləri, kontrollerləri, təhlükəsizlik alqoritmlərini və inzibati səlahiyyət (RBAC) modelini ən xırda detalına qədər izah edir. Sənəd həm proqram təminatı mühəndisləri, həm də layihə rəhbərləri və auditorlar üçün rəsmi istinad mənbəyidir.

1. Ümumi Tətbiq Haqqında Məlumat və Biznes Məqsədləri

TravelPay — Azərbaycanda gələn turistlər, yerli vətəndaşlar, merçantlar (hotellər, restoranlar, ticarət obyektləri) və inzibati orqanlar üçün nəzərdə tutulmuş müasir FinTech və Ağıllı Turizm ekosistemidir. Layihə ölkəyə daxil olan turistlərin valyuta mübadiləsi çətinliklərini aradan qaldırır, nağdsız ödənişləri təşviq edir və bütün əməliyyatları real vaxt rejimində kibertəhlükəsizlik və fırıldaqçılıq əleyhinə (Anti-Fraud) filtrasiyadan keçirir.

Əsas Funksional İstiqamətlər:

• 1. Çoxvalyutalı Rəqəmsal Pul Kisəsi (Multi-Currency Wallet): İstifadəçilər eyni hesab daxilində AZN, EUR və USD balanslarını saxlayır, anlıq bazar məzənnələri ilə konvertasiya edir və balanslarını artırırlar.

• 2. Anlıq P2P və Dinamik QR Ödənişlər: Turistlər telefon nömrəsi, email və ya dinamik generasiya olunan QR kod vasitəsilə restoranlarda, taksilərdə və muzeylərdə komissiyasız və dərhal ödəniş edə bilirlər.

• 3. Ağıllı Turizm Planlayıcısı (Smart Tourism Planner): Səyahətlərin (Trips) yaradılması, kateqoriyalar üzrə xərc büdcələrinin təyini (Nəqliyyat, Qida, Otel, Əyləncə) və xərclərin qrafik təhlili.

• 4. Virtual Aktivlər (Kripto) ilə Rezervasiya: BTC, ETH, USDT və digər kripto aktivlərin inteqrasiyası. Turistlər kriptovalyuta portfellərindən birbaşa istifadə edərək yerli otel və uçuş biletlərini bron edə bilirlər.

• 5. Real-Time Fırıldaqçılıq Aşkarlama Mühərriki (Fraud Rules Engine): Hər bir çıxan ödəniş 0–100 risk balı şkalası ilə qiymətləndirilir. Şübhəli əməliyyatlarda 2FA tələb olunur və ya vəsait yoxlama üçün saxlanılır (Hold).

• 6. İkili Qeydiyyatlı Baş Kitab (Double-Entry General Ledger): Bütün maliyyə hərəkətləri rəsmi mühasibatlıq qaydalarına uyğun olaraq Debit (DR) və Kredit (CR) balans bərabərliyi ilə arxivləşdirilir.

• 7. Qabaqcıl Rollar və İcazələr (RBAC & Department Governance): Departamentlər, İstifadəçi Qrupları və Xüsusi İcazə Nəzarəti (System Administrator & manage_permissions hüququ).

• 8. WAF & Kiber Müdafiə Qalxanı (Threat Shield): Qara siyahıya düşmüş IP-lərin avtomatik bloklanması, şübhəli cihazların təyini və dəyişdirilə bilməyən (immutable) audit jurnalları.

2. Texnoloji Stek və Arxitektura Quruluşu

Komponent	İstifadə Olunan Texnologiya	Məqsəd və Rolu
Backend Framework	Laravel 11.x (PHP 8.4)	REST API arxitekturası, Eloquent ORM, Servis qatı, Middleware və Cron planlayıcı.
Autentifikasiya	Laravel Sanctum + 2FA TOTP	Token əsaslı təhlükəsiz sessiyalar və Google Authenticator dəstəkli iki-faktorlu təsdiqləmə.
Verilənlər Bazası	MySQL 8.0 (Docker Engine)	Port 3307 üzərində işləyən, InnoDB mühərrikli, xarici açarlarla (FK) əlaqələndirilmiş əsas baza.
Keş və Sessiya	Redis / File Cache	Valyuta məzənnələrinin, API sorğu limitlərinin (Rate Limiting) və IP blokların sürətli saxlanması.
Frontend 1 (Müştəri)	Blade SPA + Vanilla JS + Tailwind	Müştəri və ümumi inzibati idarəetmə üçün sürətli, asinxron SPA interfeysi (travelpay.test).
Frontend 2 (Admin Suite)	React 19 + TypeScript + Vite	Maliyyə və kibertəhlükəsizlik heyəti üçün xüsusi analitik panel və RBAC idarəetməsi.
Qrafiklər & QR	Chart.js & QRCode.js	Tranzaksiya həcmi, risk statistikaları və dinamik QR ödəniş kodlarının vizuallaşdırılması.
Təhlükəsizlik Qatı	ThreatShield WAF Middleware	SQL injection, XSS və DDoS hücumlarının qarşısını alan qoruyucu filtr.

3. Verilənlər Bazası Sxemi, Cədvəllər və Foreign Key Əlaqələri

TravelPay verilənlər bazası relyasiyalı (RDBMS) struktura malikdir. Bütün maliyyə, təhlükəsizlik və istifadəçi məlumatları cədvəllər arasında Foreign Key (Xarici Açar) məhdudiyyətləri ilə möhkəm bağlanmışdır. Aşağıdakı cədvəldə sistemdəki bütün 23 cədvəl, onların sütunları, hansı cədvələ necə bağlandığı və silinmə zamanı davranış qaydaları (Cascade, Set Null) tam göstərilmişdir:

Cədvəl Adı	Əsas Sütunlar	Foreign Key (FK)	Bağlı Olduğu Cədvəl	Qayda / Təyinat
departments	id, name, code, manager_name, status	—	—	Təşkilati departamentlər (IT, Risk, Maliyyə, Dəstək).
user_groups	id, name, slug, department_id, is_system	**department_id**	departments (id)	ON DELETE SET NULL. Qrupun aid olduğu şöbə.
permissions	id, name, slug, category, description	—	—	Sistem icazələri (manage_permissions və s.).
group_permissions	id, user_group_id, permission_id	**user_group_id** **permission_id**	user_groups (id) permissions (id)	ON DELETE CASCADE. Qrupla İcazə arasında Çoxun-Çoxa (N:M) pivot cədvəl.
users	id, name, email, role, status, department_id, user_group_id	**department_id** **user_group_id**	departments (id) user_groups (id)	ON DELETE SET NULL. İstifadəçinin şöbəsi və səlahiyyət qrupu təyinatı.
wallets	id, user_id, wallet_number, status, daily_limit	**user_id**	users (id)	ON DELETE CASCADE. Hər istifadəçiyə 1 unikal cüzdan (1:1 münasibət).
wallet_balances	id, wallet_id, currency_code, balance, reserved_balance	**wallet_id** **currency_code**	wallets (id) currencies (code)	ON DELETE CASCADE. Hər cüzdanın AZN, EUR, USD valyuta qalıqları.
linked_bank_accounts	id, user_id, bank_name, iban, is_verified	**user_id**	users (id)	ON DELETE CASCADE. Açıq Bankçılıqla əlaqələndirilmiş bank hesabları.
virtual_cards	id, user_id, wallet_id, card_token, masked_pan, status	**user_id** **wallet_id**	users (id) wallets (id)	ON DELETE CASCADE. Təhlükəsiz virtual ödəniş kartları.
transactions	id, reference_number, user_id, wallet_id, recipient_user_id, amount, status, risk_score	**user_id** **wallet_id** **recipient_user_id**	users (id) wallets (id) users (id)	Göndərən və qəbul edən istifadəçilərə bağlı əsas maliyyə əməliyyatları.
ledger_accounts	id, account_number, account_name, type (asset, liability, equity), balance	—	—	Hesablar planı (Müştəri vəsaitləri, komissiya gəlirləri, bank ehtiyatları).
ledger_entries	id, transaction_id, ledger_account_id, entry_type (debit, credit), amount	**transaction_id** **ledger_account_id**	transactions (id) ledger_accounts (id)	İkili qeydiyyat qeydləri. Hər tranzaksiyada DR və CR balanslaşır.
fraud_rules	id, rule_code, rule_name, rule_type, condition_operator, threshold_value, risk_weight, action	—	—	Avtomatik risk qaydaları (Tezlik, həddi, IP analizi, ölkə filtri).
fraud_alerts	id, user_id, transaction_id, title, risk_score, severity, status, resolved_by	**user_id** **transaction_id** **resolved_by**	users (id) transactions (id) users (id)	Şübhəli tranzaksiya insidentləri və onları bağlayan analitik qeydi.
transaction_risk_assessments	id, transaction_id, risk_score, triggered_rules, recommended_action	**transaction_id**	transactions (id)	ON DELETE CASCADE. Hər tranzaksiya üçün çıxarılan risk auditi (1:1).
blocked_ips	id, ip_address, reason, blocked_by, expires_at	**blocked_by**	users (id)	WAF tərəfindən bloklanmış zərərli IP ünvanları.
security_events	id, user_id, event_type, ip_address, user_agent, severity	**user_id**	users (id)	Təhlükəsizlik hadisələri (Uğursuz girişlər, 2FA dəyişməsi və s.).
audit_logs	id, user_id, action, entity_type, entity_id, old_values, new_values	**user_id**	users (id)	Dəyişməz inzibati loqlar (JSON formatında əvvəlki və yeni dəyərlər).
trips	id, user_id, title, destination, start_date, end_date, total_budget	**user_id**	users (id)	ON DELETE CASCADE. Turistin yaratdığı səyahət planı.

travel_budgets	id, trip_id, category_id, planned_amount	**trip_id** **category_id**	trips (id) expense_categories (id)	ON DELETE CASCADE. Səyahət üzrə kateqoriya büdcə bölgüsü.
travel_expenses	id, trip_id, category_id, transaction_id, amount, merchant_name	**trip_id** **category_id** **transaction_id**	trips (id) expense_categories (id) transactions (id)	Səyahət daxilində faktiki baş vermiş xərclər.
travel_bookings	id, user_id, booking_type, provider_name, amount, payment_method, crypto_asset_id	**user_id** **crypto_asset_id**	users (id) crypto_assets (id)	Otel və uçuş rezervasiyaları (Fiat və ya Kripto ödənişli).
crypto_holdings	id, user_id, crypto_asset_id, balance	**user_id** **crypto_asset_id**	users (id) crypto_assets (id)	İstifadəçinin sahib olduğu kripto aktiv qalıqları (BTC, ETH, USDT).

4. Backend Servisləri, Alqoritmlər və Funksional İzah

1. FraudDetectionService.php (Fırıldaqçılıq Aşkarlama Mühərriki)

Bu servis hər bir çıxan tranzaksiyanı real vaxt rejimində təhlil edir:

• evaluate(Transaction $tx, User $user, Request $req): Əsas qiymətləndirmə metodu. Bütün aktiv fraud_rules qaydalarını oxuyur.

• checkVelocity(): İstifadəçinin son 5 və 60 dəqiqədə etdiyi əməliyyatların sayını və məbləğini yoxlayır (Sürətli ardıcıl ödəniş cəhdləri).

• checkThreshold(): Qeyri-adi böyük məbləğləri aşkar edir.

• calculateRiskScore(): Qaydaların risk çəkilərini toplayaraq 0-100 bal hesablayır.

• Qərarlar: Əgər Risk < 30 olarsa 'allow' (icazə verilir); 30-59 olarsa 'step_up_2fa' (2FA tələb olunur); 60-79 olarsa 'flag'; 80 və yuxarı olarsa tranzaksiya 'held_for_review' statusuna keçirilir və inzibatçı təsdiqi gözləyir.

2. LedgerService.php (İkili Qeydiyyatlı Baş Kitab)

Maliyyə şəffaflığı və balans bərabərliyi üçün nəzərdə tutulmuş mühasibatlıq servisi:

• recordTransaction(Transaction $tx): Tranzaksiyanın növünə görə avtomatik 2 və ya daha çox jurnal qeydi yaradır.

• recordP2PTransfer(): Göndərənin cüzdanından Debit, Alıcının cüzdanına Kredit qeyd edir.

• recordManualEntry(debit_acc, credit_acc, amount): İnzibatçının manual balans korreksiyası daxil etməsi.

• assertBalanced(): Baş kitabda Debitlərin cəminin Kreditlərin cəminə tam bərabər olduğunu riyazi olaraq təsdiqləyir (Sum(DR) == Sum(CR)).

3. WalletService.php & ExchangeRateService.php (Pul Kisəsi və Valyuta)

• transfer(): İstifadəçilər arasında P2P köçürmə. Database lock (lockForUpdate) istifadə edərək eyni anda təkrar çıxarışın (Double Spending) qarşısını alır.

• exchange(): AZN, EUR və USD arasında anlıq konvertasiya. Məzənnə marjası tətbiq olunur.

• topUp(): Açıq Bankçılıq və ya kart vasitəsilə cüzdan balansının artırılması.

• freeze() / unfreeze(): İstifadəçinin şübhəli vəziyyətdə cüzdanını dərhal 'Panic Freeze' rejiminə keçirməsi.

4. AdminController.php (Bütün İnzibati API Funksionallıqları)

Backend-də /api/v1/admin/ prefiksi ilə işləyən idarəetmə mərkəzi:

• departments(), createDepartment(), updateDepartment(), deleteDepartment(): Şöbələrin CRUD idarəsi.

• userGroups(), createUserGroup(), updateUserGroup(), deleteUserGroup(): İstifadəçi qruplarının idarəsi.

• updateGroupPermissions(): Yalnız System Administrator və ya 'manage_permissions' hüququ olanlar tərəfindən icazələrin təyini.

• users(), createUser(), updateUserStatus(): Yeni istifadəçi yaratmaq, departament/qrup təyin etmək, balansı dondurmaq.

• approveTransaction(), rejectTransaction(): Hold-a düşmüş riskli ödənişləri təsdiqləmək və ya vəsaiti geri qaytarmaq.

• creditWallet(): Müştəri cüzdanına manual kredit/depozit vermək.

• blockIp(), unblockIp(): Zərərli hücum edən IP-ləri WAF müdafiəsinə əlavə etmək.

5. ThreatShield.php (WAF Middleware) & AuditLogService.php

• ThreatShield: Hər daxil olan HTTP sorğusunun IP-sini blocked_ips cədvəli ilə yoxlayır, şübhəli User-Agent və SQL injection simvollarını dərhal 403 Forbidden ilə kəsir.

• AuditLogService: İnzibatçıların etdiyi hər bir dəyişikliyi (köhnə və yeni qiymətlər, IP, tarix) dəyişməz audit bazasına yazır.

5. Rol Əsaslı İcazələr (RBAC) və Səlahiyyət Arxitekturası

TravelPay təhlükəsizlik modelində ən vacib qaydalardan biri səlahiyyətlərin ayrılması (Separation of Duties) prinsipidir. Sistemdə icazələrin necə paylandığı aşağıdakı ciddi qaydalarla tənzimlənir:

• 1. Sistem Administratoru (System Administrator): Sistemdəki ən ali inzibati səlahiyyətli şəxsdir. Avtomatik olaraq bütün icazələrə malikdir və bütün qrupların səlahiyyətlərini tənzimləmək hüququ var.

• 2. Xüsusi manage_permissions Səlahiyyəti: Layihənin ən mühüm tələblərindən biri kimi yaradılmış xüsusi icazədir. Bu icazə adi bir qrupa və ya istifadəçiyə verildikdə, həmin istifadəçi Sistem Administratoru olmasa belə, digər qruplara icazələr verə və dəyişə bilmək hüququ qazanır.

• 3. Qorunan Giriş Filtrasiyası: Əgər daxil olmuş istifadəçi Sistem Administratoru deyilsə və onun qrupunda 'manage_permissions' icazəsi YOXDURSA, sistem icazələri dəyişməyə icazə vermir, yalnız oxu rejimini (Read-Only) aktivləşdirir və ya təhlükəsizlik baxımından qoruyucu Dashboard-a yönləndirir.

• 4. Departament Bağlantısı: Hər bir istifadəçi mütləq bir departamentə (Şöbəyə) və həmin departamentə aid olan İstifadəçi Qrupuna təyin edilə bilər. Bu, korporativ idarəetmədə hər əməkdaşın məsuliyyət zonasını müəyyən edir.

6. Əsas API Endpoint-ləri və Giriş Nöqtələri

Metod	API Endpoint	Giriş Səlahiyyəti	Funksional Təyinatı
POST	**/api/v1/auth/login**	Açıq (Public)	İstifadəçi girişi, 2FA yoxlanışı və Sanctum token verilməsi.
GET	**/api/v1/auth/me**	Auth Token	Giriş etmiş istifadəçinin profili, icazələri və cüzdan məlumatları.
GET	**/api/v1/wallet/summary**	Auth Token	Çoxvalyutalı balanslar (AZN, EUR, USD) və son tranzaksiyalar.
POST	**/api/v1/wallet/transfer**	Auth Token	Digər istifadəçiyə P2P pul köçürməsi (Fraud Engine tərəfindən yoxlanılır).
POST	**/api/v1/wallet/exchange**	Auth Token	Balans daxilində anlıq valyuta konvertasiyası.
POST	**/api/v1/payments/qr/{token}/pay**	Auth Token	Məkanda və ya restoranda dinamik QR kodla ödəniş edilməsi.
GET	**/api/v1/trips**	Auth Token	İstifadəçinin səyahət planları, büdcələri və kateqoriya xərcləri.
POST	**/api/v1/bookings**	Auth Token	Otel və ya uçuş rezervasiyası (Fiat və ya Kripto ödənişli).
GET	**/api/v1/admin/dashboard**	Admin / Perms	Maliyyə balansı, dövriyyə statistikası, risk və WAF siqnalları.
GET/POST	**/api/v1/admin/departments**	Admin / Perms	Departamentlərin siyahısı və yenisinin yaradılması.
GET/POST	**/api/v1/admin/user-groups**	Admin / Perms	İstifadəçi qruplarının siyahısı və yeni qrup açılması.
PUT	**/api/v1/admin/user-groups/{id}/permissions**	SysAdmin / manage_perms	Qrupa icazələrin təyin edilməsi və yenilənməsi.
GET/POST	**/api/v1/admin/users**	Admin / Perms	İstifadəçilərin idarəsi və sistemə yeni istifadəçi əlavə edilməsi.
POST	**/api/v1/admin/transactions/{id}/approve**	Admin / Perms	Risk səbəbilə Hold-a düşmüş ödənişin təsdiq edilməsi.
POST	**/api/v1/admin/ledger/entries**	Admin / Perms	Baş kitaba manual ikili mühasibat qeydinin daxil edilməsi.
POST	**/api/v1/admin/fraud-rules**	Admin / Perms	Yeni kiber təhlükəsizlik və risk qaydasının əlavə edilməsi.